Legal and ethical basics: authorization, scope, Rules of Engagement and the cyber-crime law that applies in your country.

Cybersecurity professionals must follow legal requirements and ethical principles when testing or protecting computer systems. Security testing should be performed only with proper authorization and within agreed limits.

Even if the purpose is learning or improving security, accessing or testing someone else's system without permission can have legal consequences.

Authorization

Authorization is formal permission from the owner or responsible authority to perform specified cybersecurity activities on a system, network, or application.

Before conducting penetration testing, scanning, or vulnerability assessment, obtain clear permission.

Example: A company gives a penetration tester written permission to assess its website for security weaknesses.

Best practices:

- Obtain written approval before testing.
- Confirm which systems are authorized.
- Follow the permitted testing methods and time limits.
- Stop if testing causes unexpected disruption or affects systems outside the authorization.

Scope

Scope defines the boundaries of a cybersecurity engagement. It specifies what can be tested and what must remain untouched.

Scope commonly includes:

- Approved IP addresses, domains, applications, and devices.

- Permitted testing techniques.
- Testing dates and time windows.
- Systems or activities explicitly excluded.
- Data-handling and reporting requirements.

Example: A company authorizes testing of its staging website but excludes its production database and payment systems.

Testing outside the approved scope is not acceptable, even if a security weakness is discovered.

Rules of Engagement (RoE)

Rules of Engagement (RoE) are agreed instructions describing how a security assessment must be conducted.

They help ensure testing is controlled, safe, and consistent with the owner's requirements.

Important elements of RoE

- **Objectives:** What the assessment is intended to achieve.
- **Authorization and scope:** Which systems may be tested.
- **Schedule:** When testing is permitted.
- **Allowed and prohibited techniques:** What actions are permitted or forbidden.
- **Communication:** Who should be contacted during testing.
- **Incident handling:** What to do if a system becomes unstable or sensitive information is discovered.
- **Evidence handling:** How findings are documented, stored, and shared.
- **Reporting:** How vulnerabilities and recommendations are delivered.

Example: A tester may be permitted to scan a staging server but prohibited from conducting denial-of-service tests.

Legal and Ethical Principles

Cybersecurity professionals should follow these principles:

- **Permission:** Never test systems without appropriate authorization.
- **Privacy:** Do not access or disclose personal or confidential information unnecessarily.

- **Confidentiality:** Protect credentials, logs, screenshots, and assessment reports.
- **Integrity:** Do not alter or delete data without explicit authorization.
- **Accountability:** Document activities and report findings honestly.
- **Responsible disclosure:** Report vulnerabilities to the appropriate owner through an agreed channel.
- **Minimum impact:** Avoid unnecessary disruption and stop if unexpected harm occurs.

Training platforms such as TryHackMe and OverTheWire provide designated environments for practising cybersecurity skills safely.

Cybercrime Law Applicable in India

In India, the **Information Technology Act, 2000**, as amended, is an important law addressing computer-related offences and other matters involving electronic systems. The specific legal provisions that apply depend on the facts of a case.

Provision	General subject
Section 43	Certain unauthorized acts involving computer systems, including unauthorized access or damage, and related compensation.
Section 66	Computer-related offences involving acts described under Section 43 when done dishonestly or fraudulently.
Section 66C	Identity theft involving another person's electronic signature, password, or other specified identification feature.
Section 66D	Cheating by personation using a computer resource or communication device.
Section 66E	Certain violations of privacy involving images of private areas without consent.

These provisions address different conduct and have specific legal requirements. Their application should be assessed using the current statutory text and relevant legal advice.

Important: Section 66A is not a valid current offence provision; it was struck down by the Supreme Court in 2015 and was subsequently omitted from the Act. Do not cite it as an operative cybercrime offence.

Other Indian laws may also apply depending on the conduct and circumstances. This section is for educational purposes and is not legal advice.

Example of Ethical vs Unethical Testing

Situation	Ethical or unethical?	Reason
Testing your own virtual machine for vulnerabilities	Ethical, if conducted safely and lawfully	You control the test environment.
Scanning a company's systems after receiving valid written approval	Potentially ethical and authorized	The activity must remain within the approved scope.
Testing a random website without permission	Unethical and potentially unlawful	There is no authorization.
Publishing passwords found during a security assessment	Unethical	It exposes sensitive information.
Reporting a vulnerability privately to the system owner	Generally responsible	It enables remediation while limiting unnecessary exposure.

Conclusion

Legal and ethical cybersecurity work requires authorization, a clearly defined scope, and agreed Rules of Engagement.

Security professionals must protect privacy, minimize harm, preserve evidence, and report findings responsibly. In India, the Information Technology Act, 2000, as amended, is a key law addressing various computer-related offences.

Always obtain permission before testing systems and use designated training environments for practice.